

Audit de Sécurité : Analyse de 3 Projets Open Source

Nextcloud – Keycloak – Suricata

TP1 : Analyse Scorecard, SBOM, CVE et Recommandations

Étudiante :

Rahimatou Iniek TAPSOBA

Mastère Expert Cybersécurité

Ynov Campus Nantes

Encadrant :

Mr BODIN

Année :

2025 – 2026

1. Introduction

Ce rapport présente l'audit de trois projets open source : **Nextcloud**, **Keycloak**, et **Suricata**. L'objectif est d'évaluer leur **gouvernance**, leur **sécurité logicielle**, leurs **dépendances**, et leurs **vulnérabilités critiques**, afin de produire :

- un **tableau d'audit Scorecard**
- une **liste de CVE critiques**
- un **SBOM CycloneDX**
- une **synthèse des risques classés par criticité**
- des **recommandations correctives documentées**

Les outils utilisés incluent : **OpenSSF Scorecard**, **OWASP Dependency-Check**, **Trivy SBOM**, et **veille CVE**.

2. Tableau d'audit Scorecard (3 projets × critères)

Projet	Score global	Points forts	Points faibles
Nextcloud	6.4 / 10	CI active, bonne maintenance	workflows dangereux, pas de fuzzing, vulnérabilités
Keycloak	9.3 / 10	gouvernance solide, fuzzing, signatures	dépendances Maven lourdes
Suricata	8.5 / 10	fuzzing, CI robuste	documentation CII faible

3. Liste des CVE critiques (CVSS, description, statut)

Nextcloud

CVE	CVSS	Description	Statut
CVE-2026-45545	8.2	SQL Injection via ORDER BY	Patch disponible
CVE-2026-45691	5.9	Bypass 2FA via cookie pré-auth	Patch disponible
CVE-2026-45690	5.9	Auth bypass via Basic Auth	Patch disponible

Keycloak

CVE	CVSS	Description	Statut
CVE-2026-9099	9.8	Escalade de privilèges Realm-Admin	Patch disponible
CVE-2026-4874	8.0	SSRF via endpoint token	Patch disponible
CVE-2026-9086	7.5	XSS via URI bypass	Patch disponible

Suricata

CVE	CVSS	Description	Statut
CVE-2026-45764	9.8	RCE via trafic réseau	Patch disponible
CVE-2026-45766	7.8	DoS via handshake TLS	Patch disponible
CVE-2026-45769	7.5	Memory exhaustion	Patch disponible

4. Synthèse des risques (Critical / High / Medium)

Projet	Risques critiques	Risques High	Risques Medium	Risque global
Nextcloud	SQLi, Auth bypass	dépendances JS/PHP	workflows dangereux	Élevé
Keycloak	PrivEsc	SSRF, XSS	dépendances Maven	Modéré

Suricata	RCE	DoS TLS	memory exhaustion	Modéré/Élevé
-----------------	-----	---------	-------------------	---------------------

Analyse synthétique

- **Nextcloud** est le plus exposé : failles d'authentification + dépendances nombreuses.
- **Keycloak** est le plus robuste : gouvernance, CI/CD, fuzzing.
- **Suricata** est le plus sensible réseau : RCE + DoS.

5. Recommandations documentées

Nextcloud

- Patch SQLi + 2FA bypass
- Activer fuzzing dans CI
- Durcir CI/CD (branch protection, tokens)
- Pinning des dépendances PHP/JS
- Activer CSP, HSTS, SameSite cookies

Keycloak

- Patch PrivEsc + SSRF + XSS
- Séparer strictement Group-Admin / Realm-Admin
- Rotation des clés JWT
- Validation stricte des URI
- Signatures obligatoires des releases

Suricata

- Patch RCE + DoS + Memory
- Durcir TLS handshake
- Limiter la mémoire dans suricata.yaml
- Activer IPS + blocage automatique
- Mise à jour des règles IDS

6. SBOM CycloneDX (Nextcloud)

Extrait SBOM CycloneDX – Nextcloud

Code

```
{
  "$schema": "http://cyclonedx.org/schema/bom-1.7.schema.json",
  "bomFormat": "CycloneDX",
  "specVersion": "1.7",
  "metadata": {
    "timestamp": "2026-06-30T07:48:33+00:00",
    "tools": {
      "components": [
        {
          "type": "application",
          "manufacturer": { "name": "Aqua Security Software Ltd." },
          "group": "aquasecurity",
          "name": "trivy",
          "version": "0.71.2"
        }
      ]
    },
    "component": {
      "type": "application",
      "name": "/root/TPInfrasOpenSource/server"
    }
  }
}
```

Extrait des composants détectés

Type	Nom	Version	Licence
library	micromark-factory-label	2.0.1	MIT
library	@vueuse/components	14.3.0	MIT
library	yargs-parser	18.1.3	MIT
library	yargs	15.4.1	MIT
library	yocto-queue	1.2.1	MIT

7. Conclusion

Cet audit met en évidence des niveaux de risques différents selon les projets :

- **Nextcloud** : risque élevé (authentification, dépendances, workflows dangereux).
- **Keycloak** : risque modéré (failles critiques mais gouvernance solide).
- **Suricata** : risque modéré/élevé (failles réseau critiques).

Les recommandations proposées permettent d'améliorer la sécurité, la gouvernance et la gestion des dépendances.